

INFORMATION SECURITY RISK ASSESSMENT

Acme Technologies, Inc. | Annual Risk Assessment Report

Prepared by: Kunj Patel, GRC Analyst | Classification: Confidential | Date: March 2026 | Version: 1.0

1. EXECUTIVE SUMMARY

This Information Security Risk Assessment was conducted for Acme Technologies, Inc., a mid-size SaaS company with approximately 150 employees operating in a hybrid cloud environment. The assessment evaluates risks across critical information assets using the NIST Cybersecurity Framework (CSF) as the guiding methodology, with risk scoring aligned to ISO 27001 risk treatment principles.

The assessment identified 10 risks across five asset categories. Of these, 3 were rated Critical, 4 High, 2 Medium, and 1 Low. Immediate remediation actions are recommended for all Critical and High-rated risks. This document serves as the primary input to Acme's risk treatment plan and should be reviewed quarterly.

2. SCOPE & OBJECTIVES

2.1 Scope

This assessment covers the following assets and environments:

- Cloud infrastructure (AWS, Microsoft Azure)
- Corporate endpoints (laptops, workstations, mobile devices)
- Identity and Access Management (IAM) systems
- Customer data and PII storage systems
- Third-party vendor integrations and APIs
- Internal network and remote access infrastructure

2.2 Objectives

- Identify and document information security risks to Acme Technologies assets
- Evaluate likelihood and impact of identified threats
- Prioritize risks using a standardized scoring methodology
- Recommend risk treatment actions aligned to NIST CSF and SOC 2 requirements
- Assign risk ownership and establish remediation timelines

3. RISK ASSESSMENT METHODOLOGY

3.1 Framework Alignment

This assessment is aligned to the NIST Cybersecurity Framework (CSF) v1.1 core functions: Identify, Protect, Detect, Respond, and Recover. Risk scoring methodology follows a 5x5 likelihood/impact matrix consistent with ISO 27001 Annex A risk treatment guidance.

3.2 Risk Scoring Matrix

Likelihood / Impact	1 - Negligible	2 - Minor	3 - Moderate	4 - Major	5 - Critical
5 - Almost Certain	5	10	15	20	25
4 - Likely	4	8	12	16	20
3 - Possible	3	6	9	12	15
2 - Unlikely	2	4	6	8	10
1 - Rare	1	2	3	4	5

3.3 Risk Rating Thresholds

Score Range	Rating	Required Action
15–25	Critical	Immediate remediation required (< 30 days)
8–14	High	Remediation required within 60 days
4–7	Medium	Remediation planned within 90 days
1–3	Low	Monitor; remediate as resources allow

4. RISK REGISTER

The following risk register documents all identified risks, their scores, owners, and recommended treatments. Risks are sorted by score from highest to lowest.

ID	Asset	Threat	Vulnerability	Like- lihood (1-5)	Impa ct (1- 5)	Scor e	Rating	Risk Owner	Recommendation	Status
R-01	Customer PII Database	Ransomware / Data Breach	Unencrypted data at rest; insufficient backup testing	5	5	25	CRITICAL	IT Security Lead	Implement AES-256 encryption at rest; test backups monthly; deploy DLP controls	Open – Due 30 days
R-02	IAM / Active Directory	Privilege Escalation	Excessive admin accounts; no PAM solution in place	4	5	20	CRITICAL	IT Manager	Implement PAM solution; enforce least privilege; conduct quarterly access reviews	Open – Due 30 days
R-03	Remote Access (VPN)	Credential Stuffing / MFA Bypass	MFA not enforced for all remote users	5	4	20	CRITICAL	IT Security Lead	Enforce MFA for 100% of remote access; review VPN logs weekly	Open – Due 30 days
R-04	Employee Endpoints	Malware / Ransomware Infection	Inconsistent EDR deployment; unpatched OS on 20% of fleet	4	4	16	HIGH	Desktop Support Lead	Deploy EDR to 100% of endpoints; enforce monthly patch cycle via Intune	In Progress – Due 60 days
R-05	Cloud Infrastructure (AWS)	Misconfiguration / Data Exposure	S3 buckets lacking public access blocks; no CSPM tooling	4	4	16	HIGH	Cloud Engineer	Enable S3 block public access; deploy CSPM tool; quarterly config reviews	Open – Due 60 days
R-06	Third-Party Vendor APIs	Supply Chain Attack	No vendor security assessments conducted; excessive API permissions	3	4	12	HIGH	Compliance Analyst	Implement vendor risk management program; conduct annual security assessments	Open – Due 60 days
R-07	Email System (M365)	Phishing / Business Email Compromise	No DMARC/DKIM enforcement; limited security awareness training	4	3	12	HIGH	IT Security Lead	Enforce DMARC/DKIM/SPF; conduct quarterly phishing simulations; mandatory SAT	In Progress – Due 60 days
R-08	Network Infrastructure	Lateral Movement / Internal Threat	Flat network; no micro-segmentation between departments	3	3	9	MEDIUM	Network Engineer	Implement VLAN segmentation; deploy internal IDS; review firewall rules quarterly	Planned – Due 90 days
R-09	Security Logging	Undetected	Incomplete log	3	3	9	MEDIUM	IT Security	Expand SIEM log sources;	Planned –

	/ SIEM	Intrusion	coverage; no 24/7 alerting for critical events					Lead	configure critical event alerting; review alert thresholds	Due 90 days
R-10	Physical Office Access	Unauthorized Physical Access	Visitor log not maintained consistently; tailgating observed	2	2	4	LOW	Facilities Manager	Implement electronic visitor log; conduct physical security awareness training	Monitor

5. NIST CSF CONTROL GAP ANALYSIS

The following table maps identified risks to NIST CSF core functions and subcategories, identifying current control gaps and recommended improvements.

Risk ID	NIST CSF Function	Subcategory	Current State	Desired State	Gap
R-01	PROTECT (PR)	PR.DS-1: Data-at-rest protection	No encryption enforced on PII database	AES-256 encryption on all data at rest	HIGH GAP
R-02	PROTECT (PR)	PR.AC-4: Access permissions managed	No PAM; excessive admin privileges	PAM solution deployed; least privilege enforced	HIGH GAP
R-03	PROTECT (PR)	PR.AC-7: Users authenticated	MFA not enforced for all remote users	MFA enforced for 100% of remote access	HIGH GAP
R-04	PROTECT (PR)	PR.IP-12: Vulnerability management plan	Inconsistent patching; partial EDR coverage	100% EDR; monthly patching enforced	MEDIUM GAP
R-05	IDENTIFY (ID)	ID.AM-3: Organizational communication mapped	No CSPM; S3 buckets misconfigured	CSPM deployed; configs reviewed quarterly	MEDIUM GAP
R-06	IDENTIFY (ID)	ID.SC-2: Suppliers assessed	No vendor risk assessments conducted	Annual vendor assessments; TPRM program	MEDIUM GAP
R-07	PROTECT (PR)	PR.AT-1: All users informed and trained	No DMARC; limited security awareness training	DMARC enforced; quarterly SAT for all staff	MEDIUM GAP
R-08	PROTECT (PR)	PR.AC-5: Network integrity protected	Flat network; no segmentation	VLAN segmentation; internal IDS deployed	LOW GAP
R-09	DETECT (DE)	DE.CM-1: Network monitored for events	Incomplete SIEM coverage; no 24/7 alerting	Full SIEM coverage; automated critical alerts	LOW GAP
R-10	PROTECT (PR)	PR.AC-2: Physical access managed	Visitor log inconsistently maintained	Electronic visitor log; physical SAT	LOW GAP

6. RISK TREATMENT PLAN & RECOMMENDATIONS

Based on the risk register, the following treatment plan prioritizes remediation actions by risk rating. All critical risks require immediate executive attention and resource allocation.

6.1 Immediate Actions (Critical – Within 30 Days)

- R-01: Engage database administrator to implement AES-256 encryption on all PII databases. Establish monthly backup testing schedule and document results for SOC 2 evidence.
- R-02: Procure and deploy a Privileged Access Management (PAM) solution. Conduct an immediate access review to identify and remove excessive admin privileges across all systems.
- R-03: Enforce MFA across 100% of remote access points including VPN, M365, and cloud consoles. Exceptions require documented business justification and CISO approval.

6.2 Short-Term Actions (High – Within 60 Days)

- R-04: Deploy EDR agent to remaining 20% of unprotected endpoints via Intune. Establish enforced monthly patch compliance reporting with exceptions tracked in risk register.
- R-05: Enable S3 Block Public Access organization-wide in AWS. Deploy Cloud Security Posture Management (CSPM) tooling and establish quarterly configuration review process.
- R-06: Develop and implement a Third-Party Risk Management (TPRM) program. Conduct initial security assessments of top 10 vendors by data access level.
- R-07: Enforce DMARC, DKIM, and SPF for all company email domains. Launch mandatory security awareness training and quarterly phishing simulation program.

6.3 Medium-Term Actions (Medium – Within 90 Days)

- R-08: Design and implement network segmentation using VLANs to isolate critical systems. Deploy internal intrusion detection and establish firewall rule review process.
- R-09: Expand SIEM log source coverage to include all critical systems. Configure automated alerting for high-priority events and establish 24/7 on-call escalation procedures.

6.4 Ongoing Monitoring (Low)

- R-10: Implement electronic visitor management system. Add physical security to annual security awareness training curriculum.

7. RISK SUMMARY & SIGN-OFF

Rating	Count	% of Total
--------	-------	------------

Critical	3	30%
High	4	40%
Medium	2	20%
Low	1	10%
Total	10	100%

This risk assessment was prepared in accordance with NIST CSF v1.1 and reflects the current security posture of Acme Technologies, Inc. as of the assessment date. Risk owners are responsible for implementing recommended treatments within the specified timelines and reporting status updates to the GRC function monthly.

Next scheduled review: June 2026 | Assessment prepared by: Kunj Patel, GRC Analyst | Approved by: Dunn Smith, CISO